Task 01

VULNERABILITY ASSESSMENT REPORT

Future Inters Cyber Security
Prepared By: Furrell Meas

Table of Contents

- Confidential....3
- Disclaimer....3
- Contact Details....3
- Executive Summary....4
- Attack Summary....5
- Detailed Findings....6
  - No HTTPS....6
  - CSP Missing....7
  - SRI Missing....8
  - Version Leak....9
- Conclusion....10

1. Confidentiality Statement

This document containts proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent.

2. Disclaimer

This assessment represents a snapshot in time. Findings reflect vulnerabilities identified during testing and may not account for changes made afterward.

3. Contact Details

Name: Furrell Meas
Email: furrelljordanmeas@gmail.com
Phone: +27 60 695 9079

4. Executive Summary

A vulnerability assessment was conducted on demo.testfire.net. The site was found to have several weaknesses that expose users to potential risks.

Total Findings	High Risk	Medium Risk	Low Risk
4	1	2	1

5. **Attack Summary**

Sl. no	Vulnerability	Recommedendation	Severity
1	No HTTPS	Implement SS:/TLS encryption	High
2	CSP Header not set	Add Control Security Policy	Medium
3	SRI Attribute Missing	Add Subresource Integrity	Meduim
4	Version Information Leak	Hide version information	Low

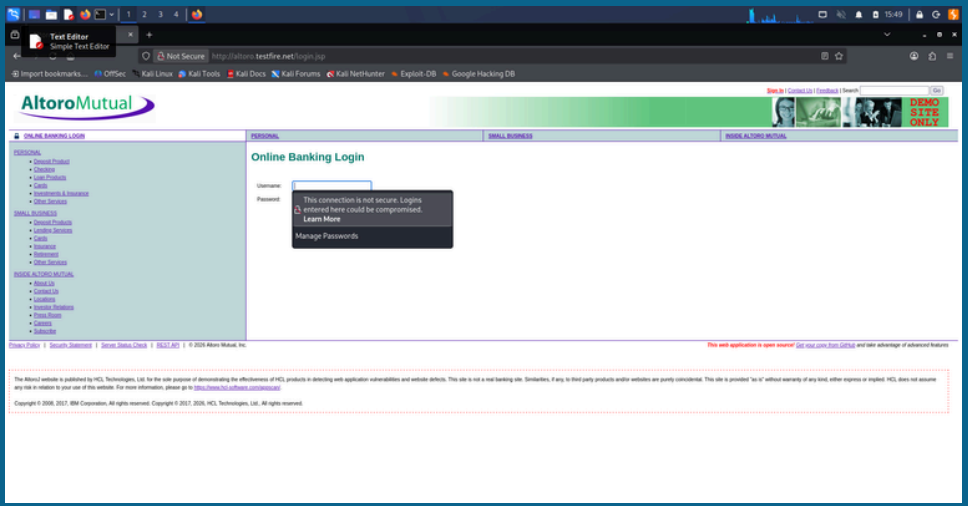
6. Detailed Findings

6.1 No HTTPS

- **Description:** The web application transmits data, in plain text, between user's browser and server unencrypted.
- **Impact:** Allows for Man-in-the-Middle attacks and data interception
- **Proof of Concept:** "Not Secure" warning when accessing the login page.

Remediation:

- redirect HTTP traffic to HTTPS & disable HTTP access
- configure TLS

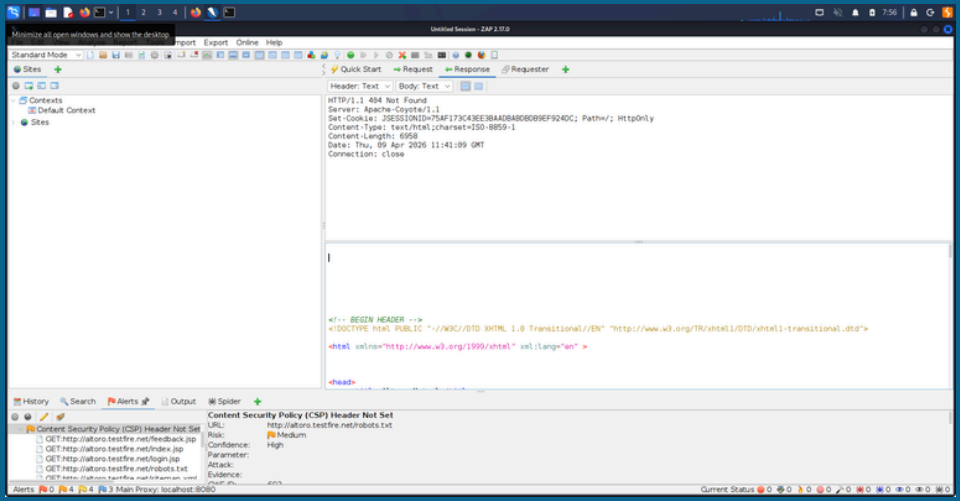


6.2 **CSP Header not Set**

- **Description:** Control Security Policy controls which resources the browser has access to.
- **Impact:** Vulnerable to loading content from untrusted sources and XSS attacks.
- **Proof of Concept:** Header missing.

Remediation:

- Implement CSP header to restrict resources.

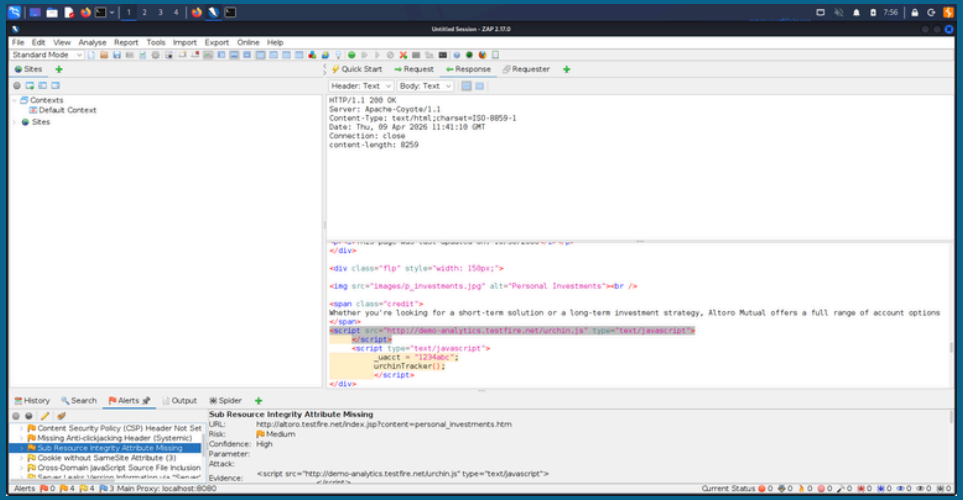


6.3 **SRI Attribute Missing**

- **Description:** Subresource Integrity Attribute verifies that files loaded from external sources have not been modified.
- **Impact:** Possible execution of altered external resources.
- **Proof of Concept:** Script from external domain does not contain SRI attribute.

Remediation:

- Implement SRI hashed for external resources.

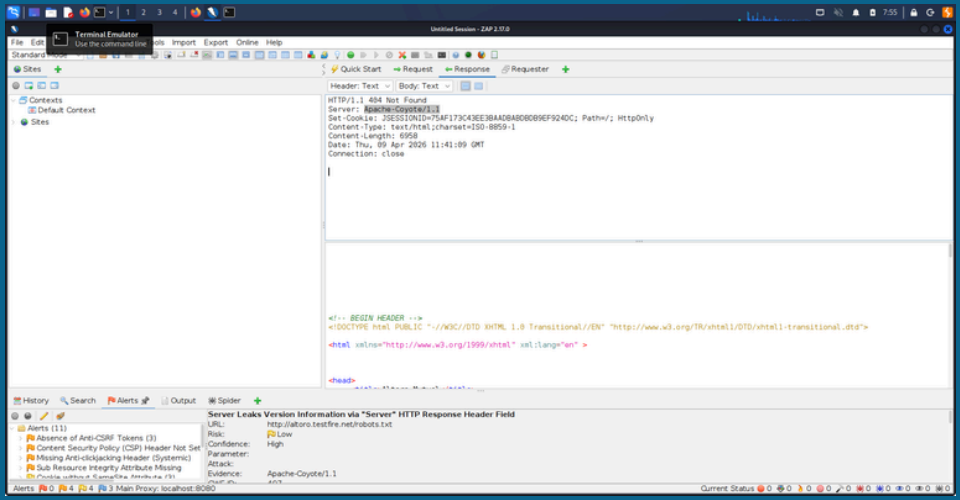


6.4 **Server Version Information Disclosure**

- **Description:** HTTP response headers reveal software version information.
- **Impact:** Allows attacker to identify known vulnerabilities associated with specific software versions.
- **Proof of Concept:** Server version found in response headers.

Remediation:

- Hide version information in response headers.
- Minimise version information in response headers.



7. Conclusion

A number of vulnerabilities were found by this vulnerability assessment, such as the lack of HTTPS encryption, the absence of Content Security Policy (CSP) headers, the absence of Subresource Integrity (SRI) attributes, and the leakage of server version information. Despite not being direct exploits, these problems undermine the application's overall security architecture and may make it easier for attackers to conduct attacks. The application's security would be greatly elevated by implementing HTTPS, providing the proper security headers, using SRI to validate external resources, and concealing server version information.